2008 Checklist

Wednesday, November 20, 2013
8:57 PM

DEPLOYMENT REVIEW CHECKLIST FOR SERVER 2008

PREPERATION

- Turn Off "Configure IE ESC"
- Turn on All Desktop Icons for Shortcuts

START & INSTALL UPDATES

- Install Service Pack 2 (Do Before you turn on updates)
- Turn on Automatic updates
- Update 3rd party Software like Apache Server if installed

INSTALL MALWARE SOFTWARE

- Run Malware Bytes

INSTALL ANTIVIRUS

- Install and Run Kaspersky

TURN ON FIREWALL

- Confirm Firewall is On
- Create Exceptions for ports that need to be open (see firewall page to the right)
- Remove exceptions that do not belong

ADD Remove programs /Features

- Remove all programs you did not install
- Do not remove Cyber Patriot
- Add/Remove Windows Features
  - Remove FTP, SNMP, SMTP, TELNET, Internet Printing …….

SEARCH FOR COMMON BAD FILES

- Hit <Windows>+F and Copy and paste the following:
- Win1.exe; Win2.exe; Win3.exe; backd00r.exe; asdf.exe; BFK.exe; taskmgr.exe.exe; spyr.exe; nc.exe; fgdump.exe; nginx.exe

SERVER ROLES

- Remove Unrequired Roles
- Add required roles

COMPUTER MANAGER (COMPMGNT.MSC)

- Drives must be NTFS on Drives
- Remove all users from Administrator group that are not required
- Change All User passwords and Select uncheck
- Disable Windows Guest Account 5
- IWAM/IUSR_<MACHINENAME> account is disabled if not used 5
- Multiple Local Administrator Accounts 6
- All unnecessary shares are removed
- Access to Shares Using Privileged Accounts 8
- Remove shares from System Drive
- Unnecessary service(s) running
  - Telnet (TCP/23),
  - Remote Desktop
  - (TCP/3389),
  - Remote Registry (TCP/445)
  - SMTP (TCP/25)
  - World Wide Publishing (TCP/80)
  - File Transfer Protocol (TCP/25)
- IIS Server and SQL Server are on the same server 10
- Rename Local Administrator Account **: Set to Saxon**
- Rename Windows Guest account :**Set to NotSaxon**
- Service accounts are running under elevated Rights 12
- Service Accounts Must Not be Part of Administrators 13
- Remote Registry service must be set to Manual 13
- Verify Event Viewer Logs have an Appropriate Size 14
- Verify that IUSR* not part of Guests Group

Turn on UAC

Security Policies (SECPOL.MSC)

- Minimum Password Age: **5 Days**
- Enforce Password History: **24 (standard for Domains)**
- Maximum Password Age: **42 Days**
- Minimum Password Length: **8**
- Password Must meet Complexity Requirement: **Enabled**
- Store Password using reversible Encryption for all users in the Domain: **Disabled**
- Account Lock out Duration: **10 Minutes**
- Account Lock out Threshold: **20**

Reset Account Lock out after: **30 Minutes**

Reset Account Lock out after: **30 Minutes**

AUDIT POLICIES

Check all to set Success and Failure

USER RIGHTS ASSIGNMENT

Who can Access this computer from the network: **Administrator, Authenticated Users**
Add Workstations to the domain: **Administrators**
Allow Log on Locally: **Administrators**
Allow log on through terminal Service: **Administrators**
Bypass Traverse Checking: **Remove Everyone Group and Users, Add Administrators**
Deny Access to this computer from the network: **ANONYMOUS LOGON and Guest account**
Force Shutdown from a remote system: **Administrators**
Generate Security Audits: **Ensure that only the Service and Network Service accounts**
Log on as a service: **Local System, Local Service, and Network Service**
Restore Files and Directories: **local Administrators group**
Shut Down the system: **Administrators and Backup Operators**

Security Options

Accounts: Administrator account status :**Disable (Make sure you are using a different user in the administrators group)** Accounts: Guest account status: **Disabled**
Accounts: Limit local account use of blank passwords to console logon only: **Enabled**
Accounts: Rename administrator account: **Change to "Saxons"**
Accounts: Rename guest account: **Change to "NotSaxons"**
Audit: Audit the access of global system objects : **No Change**
Audit: Audit the use of Backup and Restore privilege : **No Change**
Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings : **No Change** Audit: Shut down system immediately if unable to log security audits: **Enabled**
DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) : **No Change**
DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) : **No Change**
Devices: Allow undock without having to log on : **No Change**
Devices: Allowed to format and eject removable media: **Administrators**
Devices: Prevent users from installing printer drivers: **Enable**
Devices: Restrict CD-ROM access to locally logged-on user only: **Enable**
Devices: Restrict floppy access to locally logged-on user only: **Enable**
Devices: Unsigned driver installation behavior Need to get setting
Domain controller: Allow server operators to schedule tasks: **Disable**
Domain controller: LDAP server signing requirements: **No Change**
Domain controller: Refuse machine account password changes: **No Change**
Domain member: Digitally encrypt or sign secure channel data (multiple related settings): **No Change**
Domain member: Disable machine account password changes: **No Change**
Domain member: Maximum machine account password age: **30 Days**
Domain member: Require strong (Windows 2000 or later) session key: **Enable**
Interactive logon: Do not display last user name: **Enable**
Interactive logon: Do not require CTRL+ALT+DEL: **Disable**
Interactive logon: Message text for users attempting to log on and Message title for users attempting to log on: **Set to "Saxons Rock"**
Interactive logon: Number of previous logons to cache (in case domain controller is not available)**: Set to 0**
Interactive logon: Prompt user to change password before expiration**: 14 Days**
Interactive logon: Require Domain Controller authentication to unlock workstation: **No Change**
Interactive logon: Require smart card: **No Change**
Interactive logon: Smart card removal behavior: **No Change**

Microsoft network client and server: Digitally sign communications (four related settings)

Disable Microsoft Network Client: Digitally Sign Communications (Always).

Disable Microsoft Network Server: Digitally Sign Communications (Always).

Enable Microsoft Network Client: Digitally Sign Communications (If Server Agrees).

Enable Microsoft Network Server: Digitally Sign Communications (If Client Agrees).
Microsoft network client: Send unencrypted password to third-party SMB servers**: Disable**
Microsoft network server: Amount of idle time required before suspending session: **No Change**
Microsoft network server: Disconnect clients when logon hours expire**: Enable**
Network access: Allow anonymous SID/Name translation**: Disable**
Network access: Do not allow anonymous enumeration of SAM accounts **:Enable**
Network access: Do not allow anonymous enumeration of SAM accounts and shares: **Enable**
Network access: Do not allow storage of credentials or .NET Passports for network authentication**: Enable**
Network access: Let Everyone permissions apply to anonymous users**: Disable**
Network access: Named Pipes that can be accessed anonymously: **enable the setting but do not specify named pipes in the text box** Network access: Remotely accessible registry paths: **enable the setting but do not enter any paths in the text box**
Network access: Remotely accessible registry paths and sub-paths: **enable the setting but do not enter any paths in the text box** Network access: Restrict anonymous access to Named Pipes and Shares: **Enable**
Network access: Shares that can be accessed anonymously**: Set to Null**
Network access: Sharing and security model for local accounts: **Classic – local users authenticate as themselves**
Network security: Do not store LAN Manager hash value on next password change**: Enable**
Network security: Force logoff when logon hours expire**: Enable**
Network security: LAN Manager authentication level: **Send NTLMv2 responses only**
Network security: LDAP client signing requirements: **Require signature**.

Network security: Minimum session security for NTLM SSP based (including secure RPC) clients : **Enable all four options** Server 2008

Network security: Minimum session security for NTLM SSP based (including secure RPC) clients : **Enable all four options** Network security: Minimum session security for NTLM SSP based (including secure RPC) servers
Recovery console: Allow automatic administrative logon**: Disable**

Recovery console: Allow floppy copy and access to all drives and all folders**: Disable**
Shutdown: Allow system to be shut down without having to log on**: Disable**
Shutdown: Clear virtual memory pagefile**: Enable**
System cryptography: Force strong key protection for user keys stored on the computer: **No Change**
System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing: **No Change**
System objects: Default owner for objects created by members of the Administrators group
System objects: Require case insensitivity for non-Windows subsystems: **No Change**
System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links): **No Change**
System settings: Optional subsystems: **No Change**
System settings: Use Certificate Rules on Windows Executables for Software Restriction Policies: **No Change**
User Account Control: Admin Approval Mode for the Built-in Administrator account**: Enable**
User Account Control: Allow UIAccess applications to prompt for elevation without using the secure desktop **: Disable**
User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode **: Prompt for Consent** User Account Control: Behavior of the elevation prompt for standard users: **Automatically deny elevation requests** User Account Control: Detect application installations and prompt for elevation**: Enabled**
User Account Control: Only elevate executables that are signed and validated**: Enable**
User Account Control: Only elevate UIAccess applications that are installed in secure locations: **No Change** User Account Control: Run all administrators, in Admin Approval Mode**: Enable**
User Account Control: Switch to the secure desktop when prompting for elevation**: Enable**

☐ User Account Control: Virtualize file and registry write failures to per-user locations: **No Change**

☐ **CONTROL PANEL 15**
Tools like Visual Studio or SDKs installed 15
Verify User Account Control is Enabled Correctly 17

☐ Secure Extranet-Facing Network Card Interface (NIC) 17

☐ **EXPLORER 18**
Restrict Access Control for Root Drives 18
Everyone group has access to Web directories 19
Everyone group has access to \WINNT\SYSTEM32 Got us to Nationals
Metabase.xml file Access Control is Excessive 21

☐ Remove Unnecessary Files and Directories 21

☐ **Operating System 48**
Sites using TLS/SSL and Integrated Windows AuthN must use Extended Protection 48
Windows Firewall is not Enabled 50
Verify Anti-Virus Signatures are up-to-date 51
Verify Two-Factor Authentication on Extranet-Facing Servers 51

☐ User Account Control is not Enabled Correctly 52

☐ **REGISTRY 53**
TCP/IP stack is not hardened 53
Null Sessions are not allowed 53
Security Accounts Manager is not hardened 54

☐ Verify CD AutoRun is Disabled 55

☐ **SECPOL.MSC 56**
Enforce Strong Password Policy 56
Everyone group is being allowed "Access this computer from the network" 57
Remote Logins are not restricted 57
Set every audit policy to "Checked"
Store Passwords Using Reversible Encryption should be disabled 59

☐ Comply with Account Lockout Policy for Extranet-Facing Servers 60

☐ **Server Manager 61**
Verify Server has Correct Roles, Role Services and Features 61

Disable Services

- **Default is Started by Default**
- **Default Not started by Default**

Application Layer Gateway Service Disabled
Application Management Disabled
Background Intelligent Transfer Service Disabled
Block Level Backup Engine Service Disabled
CNG Key Isolation Disabled
Computer Browser Disabled
Diagnostic Policy Service Disabled
Diagnostic Service Host Disabled
Diagnostic System Host Disabled
Human Interface Device Access Disabled
Internet Connection Sharing (ICS) Disabled
IP Helper Disabled
IPsec Policy Agent Disabled

☐ ☐ KtmRm for Distributed Transaction Coordinator Disabled

KtmRm for Distributed Transaction Coordinator Disabled
Microsoft iSCSI Initiator Service Disabled
Network Access Protection Agent Disabled

Offline Files Disabled
Parental Controls Disabled
Peer Name Resolution Protoco Disabled
Peer Networking Grouping Disabled
Peer Networking Identity Manager Disabled
PnP-X IP Bus Enumerator Disabled
PNRP Machine Name Publication Service Disabled
Print Spooler Disabled
Quality Windows Audio Video Experience Disabled
ReadyBoost Disabled
Remote Registry Disabled
Routing and Remote Access Disabled
Secondary Logon Disabled
Server Disabled Kills the Admin Shares Smart Card Disabled
Smart Card Removal Policy Disabled
SNMP Trap Disabled
Superfetch Disabled
Tablet PC Input Service Disabled
TCP/IP NetBIOS Helper Disabled
Terminal Services Disabled
Terminal Services Configuration Disabled
Terminal Services UserMode Port Redirector Disabled
Windows Backup Disabled
Windows Defender Disabled
Windows Error Reporting Service Disabled
Windows Media Center Extender Service Disabled
Windows Modules Installer Disabled
Windows Remote Management (WS-Management) Disabled
Windows Search Disabled
WinHTTP Web Proxy Auto-Discovery Service Disabled
WLAN AutoConfig Disabled

TOOLS

Run MBSA against server being reviewed
Run WACA and fix resulting issues
Run Secunia to see if software needs updates
Sysinternals
ProcessViewer
ShareEnum.exe
Streams.exe
TCPView.exe
CCleaner

Add Critical Services as dictated by the scenario

Goto Start à Administrative Tools à Server Manager à Roles à Add Roles
Confirm that all ports for services are active by using netstat -ano

Turn On "Configure IE ESC"

TERMINAL SERVER 86

Incorrect IIS Virtual Directory Settings 22
Remote desktop is not set to High or Fips Compliant encryption level 86
Terminal Services are not configured to expire after 30 minutes 87

SQL CHECKLIST

SQL CONFIGURATION MANAGER 66

SQL Named Instance is Using Dynamic Port Assignments 66
Disable All Protocols except TCP/IP within SQL Server 66
SQL Communication Channel is not Encrypted 67
Configure SQL Server with Certificate from Trusted Authority 68

SQL MANAGER 69

Remove Sample Databases 69
SQL Authentication is Enabled 70
Verify logging of Failed Logins 71
C2 Audit Mode selected if HBI data is transported 71
SQL Logs not secured with access control lists 72
SQL Accounts do not comply with MS policies (MSInternal) 73
Sysadmins Group Has More Than 2 Users 74
SQL Admins Do Not Have Strong Password Policy 75
Remove Public Permissions for Extended Stored Procedures 76
Unused accounts are removed from Windows and SQL Server 78
Remove IIS7 Metabase Compatibility Feature 25

IIS MANAGER 22

Use IIS ports 80 and 443 25
IIS Logging is not configured for W3C Extended log file format 26
IIS Log files are located on a system drive 27
IIS Logging Contains Useful Information 28
Websites is on System Drive 29
Remove Write Permission for Anonymous Internet accounts 29
Verify Server Certificates are Valid (MSInternal) 30
Verify that Certificates are being used correctly 32
Remove Unnecessary ISAPI filters 32
Web application pool is Running as Admin 33
Unnecessary WebDav/Service Extensions not Disabled 34
Remove Unneeded IIS Services 35
Remove default web site 36
Enable Extended Protection for an SSL/TLS-Protected Site - IIS 6 37
Enable Extended Protection for an SSL/TLS-Protected Site - IIS 7 39
Enable Extended Protection for an SSL/TLS-Protected Site - IIS 7.5 42
Remove Unnecessary Handler Mappings 44
Verify Default Document is Correct 45
Remove Sample IIS Sites 46
Remove Unused Script Mappings 46
Only Use Basic Authentication with SSL 47

Simple Mail Transfer Protocol (SMTP) 62

Sysadmins Group Has More Than 2 Users 74
SQL Admins Do Not Have Strong Password Policy 75 Remove
Public Permissions for Extended Stored Procedures 76 Unused
accounts are removed from Windows and SQL Server 78 Disable
Guest account on SQL Server 78
BUILTIN\Administrators server login is removed from sysadmin 79

xp_cmdshell is not disabled 80
SQL Passwords are older than 70 days 82
Should use NTLMv2 83
Service Accounts should not be part of Sysadmin role 84 SQL
Logon Accounts Must Follow Strong Password Policy 84
Reduce or Avoid use of db_datareader and db_datawriter 85
Remove Sample IIS Sites 46
Remove Unused Script Mappings 46
Only Use Basic Authentication with SSL 47

Simple Mail Transfer Protocol (SMTP)

62 SMTP Authentication is Weak 62
SMTP is not Logging Correctly 63
SMTP SHOULD be using TLS to encrypt traffic 64
SMTP bad mail folder in default location on system drive 64
SMTP should be removed if not needed 65